

A. Introduction

1. **Title:** Cyber Security — Electronic Security Perimeter(s)
2. **Number:** RRC-CIP-005-1
3. **Purpose:** To protect BES Cyber Systems (BCS) against compromise by permitting only known and controlled communication to reduce the likelihood of misoperation or instability in the Bulk Electric System (BES).
4. **Applicability:**
 - 4.1. **Functional Entities:** For the purpose of the requirements contained herein, the following list of functional entities will be collectively referred to as “Responsible Entities.” For requirements in this standard where a specific functional entity or subset of functional entities are the applicable entity or entities, the functional entity or entities are specified explicitly.
 - 4.1.1. **Balancing Authority**
 - 4.1.2. **Distribution Provider:** that owns one or more of the following Facilities, systems, and equipment for the protection or restoration of the BES:
 - 4.1.2.1. Each underfrequency load shedding (UFLS) or undervoltage loadshedding (UVLS) system that:
 - 4.1.2.1.1. is part of a Load shedding program that is subject to one or more requirements in an Railbelt Reliability Council Standard; and
 - 4.1.2.1.2. performs automatic Load shedding under a common control system owned by the Responsible Entity, without human operator initiation, that the loss, compromise, or misuse could have an adverse impact on the reliable operation of the BES.
 - 4.1.2.2. Each Remedial Action Scheme (RAS) where the RAS is subject to one or more requirements in an Railbelt Reliability Council Standard.
 - 4.1.2.3. Each Protection System (excluding UFLS and UVLS) that applies to Transmission where the Protection System is subject to one or more requirements in an Railbelt Reliability Council Standard.
 - 4.1.2.4. Each Cranking Path and group of Elements meeting the initial switching requirements from a Blackstart Resource up to and including the first interconnection point of the starting station service of the next generation unit(s) to be started.
 - 4.1.3. **Generator Operator**
 - 4.1.4. **Generator Owner**
 - 4.1.5. **Transmission Operator**
 - 4.1.6. **Transmission Owner**
 - 4.2. **Facilities:** For the purpose of the requirements contained herein, the following Facilities, systems, and equipment owned by each Responsible Entity in 4.1 above are those to which these requirements are applicable. For requirements in this standard where a specific type of Facilities, system, or equipment or subset of Facilities, systems, and equipment are

applicable, these are specified explicitly.

4.2.1. Distribution Provider: One or more of the following Facilities, systems and equipment owned by the Distribution Provider for the protection or restoration of the BES:

4.2.1.1. Each UFLS or UVLS System that:

4.2.1.1.1. is part of a Load shedding program that is subject to one or more requirements in an Railbelt Reliability Council Standard; and

4.2.1.1.2. performs automatic Load shedding under a common control system owned by the Responsible Entity, without human operator initiation, that the loss, compromise, or misuse could have an adverse impact on the reliable operation of the BES.

4.2.1.2. Each RAS where the RAS is subject to one or more requirements in an Railbelt Reliability Council Standard.

4.2.1.3. Each Protection System (excluding UFLS and UVLS) that applies to Transmission where the Protection System is subject to one or more requirements in an Railbelt Reliability Council Standard.

4.2.1.4. Each Cranking Path and group of Elements meeting the initial switching requirements from a Blackstart Resource up to and including the first interconnection point of the starting station service of the next generation unit(s) to be started.

4.2.2. Responsible Entities listed in 4.1 other than Distribution Providers:

All BES Facilities.

4.2.3. Exemptions: The following are exempt from Standard **RRC-CIP-005-1**:

4.2.3.1. Cyber Systems at Facilities regulated by the Canadian Nuclear Safety Commission.

4.2.3.2. Cyber Assets associated with communication networks and data communication links between discrete Electronic Security Perimeters (ESP).

4.2.3.3. Cyber Systems, associated with communication networks and data communication links, between Cyber Systems, providing confidentiality and integrity of an ESP that extends to one or more geographic locations.

4.2.3.4. The systems, structures, and components that are regulated by the Nuclear Regulatory Commission under a cyber security plan pursuant to 10 C.F.R. Section 73.54.

4.2.3.5. For Distribution Providers, the systems and equipment that are not included in section 4.2.1 above.

4.2.3.6. Responsible Entities that identify that they have no BES Cyber Systems categorized as high impact or medium impact according to the CIP-002 identification and categorization

processes.

- 4.3. “Applicable Systems”:** Each table has an “Applicable Systems” column to define the scope of systems to which a specific requirement part applies.
- 5. Effective Dates:** Shall become effective on the first day of the first calendar quarter that is twenty-four (24) calendar months following adoption by the Approving Authority.

B. Requirements and Measures

- R1.** Each Responsible Entity shall implement one or more documented processes that collectively include each of the applicable requirement parts in *RRC-CIP-005-1 Table R1 – Electronic Security Perimeter*. [Violation Risk Factor: Medium].
- M1.** Evidence must include each of the applicable documented processes that collectively include each of the applicable requirement parts in *RRC-CIP-005-1 Table R1 – Electronic Security Perimeter* and additional evidence to demonstrate implementation as described in the Measures column of the table.

RRC-CIP-005-1 Table R1 – Electronic Security Perimeter			
Part	Applicable Systems	Requirements	Measures
1.1	High Impact BCS and their associated Protected Cyber Asset (PCA) Medium Impact BCS and their associated PCA	Applicable Systems connected to a network via a routable protocol must be protected by an Electronic Security Perimeter (ESP).	Examples of evidence may include, but is not limited to, a list of all ESPs with all uniquely identifiable applicable Cyber Systems connected via a routable protocol within each ESP.
1.2	High Impact BES Cyber Systems with External Routable Connectivity (ERC) and their associated PCA Medium Impact BCS with ERC and their associated PCA	Permit only needed routable protocol communications, documenting the reason, and deny all other routable protocol communications, through the ESP; excluding time sensitive communications of Protection Systems.	Examples of evidence may include, but are not limited to, documentation that includes the configuration of system and documented reason, such as: • Electronic Access Point (EAP) configuration; • Network infrastructure configuration (e.g., technical policies, ACL, VLAN, VXLAN, MPLS, VRF, multi-context, or multi-tenant environment); or • Shared Cyber Infrastructure (SCI) configuration or settings (e.g., technical policies, hypervisor, fabric, back-plane, or SAN configuration).

RRC-CIP-005-1 Table R1 – Electronic Security Perimeter			
Part	Applicable Systems	Requirements	Measures
1.3	Shared Cyber Infrastructure (SCI) supporting an Applicable System from Part 1.1. Electronic Access Control or Monitoring Systems (EACMS), and their supporting SCI, that control an ESP for an Applicable System in Part 1.1	Protect ESP and SCI configurations by implementing methods to permit only needed network accessibility to Management Interfaces of Applicable Systems, per system capability.	Examples of evidence may include, but are not limited to, documentation of the methods implemented to permit only needed network accessibility to Management Interfaces, including documented reasons such as: • Logical configuration or settings (e.g., technical Policies, ACL, VLAN, VXLAN, MPLS, VRF, multi-context, or multi-tenant environment); • Physically isolated or out-of-band network for dedicated Management Interfaces; or • SCI configuration or settings showing the isolation of the Management Interfaces (e.g., technical policies, hypervisor, fabric back-plane, or SAN configuration).
1.4	High impact BCS and their associated PCA Medium impact BCS and their associated PCA SCI supporting an Applicable System in this Part	Perform authentication when establishing Dial-up Connectivity with Applicable Systems, if any, and per system capability.	Examples of evidence may include, but are not limited to, configuration, settings, or documented process that describes how the Responsible Entity is providing authenticated access through each dial-up connection.

RRC-CIP-005-1 Table R1 – Electronic Security Perimeter			
Part	Applicable Systems	Requirements	Measures
1.5	High impact BCS Medium impact BCS at Control Centers	Have one or more methods for detecting known or suspected malicious routable protocol communications entering or leaving an ESP.	An example of evidence may include, but is not limited to, documentation that malicious routable protocol communications detection methods (e.g., intrusion detection system, application layer firewall, etc.) are implemented.
1.6	High impact BCS and their associated PCA Medium impact BCS at Control Centers and their associated PCA	Protect the data traversing communication links used to span a single ESP between PSPs through the use of: • Confidentiality and integrity controls, or • Physical controls that restrict access to the cabling and other non-programmable communication components in those instances when such cabling and components are located outside of a PSP, Excluding: - Real-time Assessment and Real-time monitoring data while being transmitted between Control Centers subject to CIP-012; and - Time-sensitive communication of Protection Systems.	Examples of evidence may include, but are not limited to, documentation of methods used to protect the confidentiality and integrity of the data, such as: • Configurations or settings used to enforce encryption; or • The physical access restrictions (e.g., cabling and components secured through conduit or secured cable trays).

- R2.** Each Responsible Entity shall implement one or more documented processes that collectively include the applicable requirement parts, per system capability, in *CIP-005-1 Table R2 – Remote Access Management*. [Violation Risk Factor: Medium]
- M2.** Evidence must include the documented processes that collectively address each of the applicable requirement parts in *CIP-005-1 Table_R2 – Remote Access Management* and additional evidence to demonstrate implementation as described in the Measures column of the table.

RRC-CIP-005-1 Table R2 –Remote Access Management			
Part	Applicable Systems	Requirements	Measures
2.1	High Impact BCS and their associated PCA Medium Impact BCS and their associated PCA SCI supporting an Applicable System in this Part	Permit Interactive Remote Access (IRA), if any, only through an Intermediate System.	Examples of evidence may include, but are not limited to, network diagrams or architecture documents, configuration, or settings that show all IRA is through an Intermediate System.
2.2	Intermediate System(s) used to access an Applicable System in Part 2.1	Protect the confidentiality and integrity of IRA communications between the initiating Cyber Asset or Virtual Cyber Asset and the Intermediate System.	Examples of evidence may include, but are not limited to, architecture documents, configuration or settings detailing where confidentiality and integrity controls (e.g., encryption) initiate and terminate.

RRC-CIP-005-1 Table R2 –Remote Access Management			
Part	Applicable Systems	Requirements	Measures
2.3	Intermediate System(s) used to access an Applicable System in Part 2.1	Require multi-factor authentication to the Intermediate System for IRA communications between the initiating Cyber Asset or Virtual Cyber Asset and the Intermediate System.	Example of evidence may include, but are not limited to, architecture documents, configuration or settings detailing the authentication factors used. - Examples of authenticators may include, but are not limited to, - Something the individual knows such as passwords or PINs. This does not include User ID; - Something the individual has such as tokens, digital certificates, or smart cards; or - Something the individual is such as fingerprints, iris scans, or other biometric characteristics.

RRC-CIP-005-1 Table R2 –Remote Access Management			
Part	Applicable Systems	Requirements	Measures
2.4	High Impact BCS and their associated PCA Medium Impact BCS and their associated PCA SCI supporting an Applicable System in this Part	Have one or more methods for determining active vendor remote access sessions (including Interactive Remote Access and system-to-system remote access).	Examples of evidence may include, but are not limited to, documentation of the methods used to determine active vendor remote access (including Interactive Remote Access and system-to-system remote access), such as: • Methods for accessing logged or monitoring information to determine active vendor remote access sessions; • Methods for monitoring activity (e.g. connection tables or rule hit counters in a firewall, or user activity monitoring) or open ports (e.g. netstat or related commands to display currently active ports) to determine active system to system remote access sessions; or • Methods that control vendor initiation of remote access such as vendors calling and requesting a second factor in order to initiate remote access.

RRC-CIP-005-1 Table R2 –Remote Access Management			
Part	Applicable Systems	Requirements	Measures
2.5	High Impact BCS and their associated PCA Medium Impact BCS and their associated PCA SCI supporting an Applicable System in this part	Have one or more method(s) to disable active vendor remote access (including Interactive Remote Access and system-to-system remote access).	Examples of evidence may include, but are not limited to, documentation of the methods(s) used to disable active vendor remote access (including Interactive Remote Access (IRA) and system-to-system remote access.)
2.6	Intermediate System(s) used to access an Applicable System in Part 2.1	Prevent Intermediate System(s) from sharing CPU resources and memory resources with any part of a high or medium impact BCS or associated PCAs.	Examples of evidence may include, but are not limited to, documentation that includes the following: - Intermediate System architecture; or - Configuration or settings of each Intermediate System and supporting Cyber Systems.
2.7	Intermediate System(s) used to access an Applicable System in Part 2.1	Routable protocol communications from an Intermediate System to a high or medium impact BCS or associated PCAs must be through an ESP.	Examples of evidence may include, but are not limited to, documentation that includes the following: - Network diagrams of Intermediate Systems architecture; or - Configuration, settings, or policy of the EAP which controls routable protocol communications of IRA through the ESP.

- R3.** Each Responsible Entity shall implement one or more documented processes that collectively include the applicable requirement parts in *CIP-005-1 Table R3 –Vendor Remote Access Management for EACMS, PACS, and SCI*. [Violation Risk Factor: Medium]
- M3.** Evidence must include the documented processes that collectively address each of the applicable requirement parts in *CIP-005-1 _Table_R3_– Vendor Remote Access Management for EACMS,_PACS,_and SCI* and additional evidence to demonstrate implementation as described in the Measures column of the table.

RRC-CIP-005-1 Table R3 – Vendor Remote Access Management for EACMS, PACS, and SCI			
Part	Applicable Systems	Requirements	Measures
3.1	EACMS and PACS associated with high impact BCS. EACMS and PACS associated with medium impact BCS with ERC. SCI supporting an Applicable System in this Part .	Have one or more method(s) to determine authenticated vendor-initiated remote connections.	Examples of evidence may include, but are not limited to, documentation of the methods used to determine authenticated vendor-initiated remote connections, such as: • Methods for accessing logged or monitoring information to determine authenticated vendor-initiated remote connections.

RRC-CIP-005-1 Table R3 – Vendor Remote Access Management for EACMS, PACS, and SCI			
Part	Applicable Systems	Requirements	Measures
3.2	EACMS and PACS associated with high impact BCS. EACMS and PACS associated with medium impact BCS with ERC. SCI supporting an Applicable System in this Part.	Have one or more method(s) to terminate authenticated vendor-initiated remote connections and control the ability to reconnect.	Examples of evidence may include, but are not limited to, documentation of the methods(s) used to terminate authenticated vendor-initiated remote connections to applicable systems. Examples include terminating an active vendor-initiated shell/process/session or dropping an active vendor-initiated connection in a firewall. Methods to control the ability to reconnect, if necessary, could be: disabling an Active Directory account; disabling a security token; restricting IP addresses from vendor sources in a firewall; or physically disconnecting a network cable to prevent a reconnection.

C. Compliance

1. Compliance Monitoring Process

1.1 Compliance Enforcement Authority

The RRC is the entity with the authority to monitor and enforce compliance with mandatory and enforceable Railbelt Reliability Council Standards.

1.2 Evidence Retention

The following evidence retention periods identify the period of time an entity is required to retain specific evidence to demonstrate compliance. For instances where the evidence retention period specified below is shorter than the time since the last audit, the RRC may ask an entity to provide other evidence to show that it was compliant for the full time period since the last audit.

The Responsible Entity shall keep data or evidence to show compliance as identified below unless directed by the RRC to retain specific evidence for a longer period of time as part of an investigation:

- Each Responsible Entity shall retain evidence of each requirement in this standard for three calendar years.
- If a Responsible Entity is found non-compliant, it shall keep information related to the non-compliance until mitigation is complete and approved or the time specified above, whichever is longer.
- The RRC shall keep the last audit records and all requested and submitted subsequent audit records.

1.3 Compliance Monitoring and Enforcement Program:

Compliance Monitoring and Enforcement Program refers to the identification of the processes that will be used to evaluate data or information for the purpose of assessing performance or outcomes with the associated Railbelt Reliability Council Standards.

Table of Compliance Elements

R#	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-003-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
R1	Medium	The Responsible Entity did not address one of the nine topics required by Requirement R1. (R 1.1)	The Responsible Entity did not address two of the nine topics required by Requirement R1. (R 1.1)	The Responsible Entity did not address four of the nine topics required by Requirement R1. (R 1.1)	The Responsible Entity did not address six or more of the nine topics required by Requirement R1. (R 1.1)
		OR	OR	OR	OR
		The Responsible Entity did not complete its review of the one or more documented cyber security policies for its high impact and medium impact BCS as required by Requirement R1 within 15 calendar months but did complete this review in less than or equal to 17 calendar months of the previous review. (R 1.1)	The Responsible Entity did not complete its review of the one or more documented cyber security policies for its high impact and medium impact BCS as required by Requirement R1 within 17 calendar months but did complete this review in less than or equal to 19 calendar months of the previous review. (R 1.1)	The Responsible Entity did not complete its review of the one or more documented cyber security policies for its high impact and medium impact BCS as required by Requirement R1 within 19 calendar months but did complete this review in less than or equal to 21 calendar months of the previous review. (R 1.1)	The Responsible Entity did not have any documented cyber security policies for its high impact and medium impact BCS as required by Requirement R1. (R 1.1)
		OR	OR	OR	OR
		The Responsible Entity did not complete its approval of the one or more documented cyber security policies for its high impact and medium impact BCS as required by	The Responsible Entity did not complete its approval of the one or more documented cyber security policies for its high impact and medium impact BCS as required by Requirement R1 by the CIP	The Responsible Entity did not complete its approval of the one or more documented cyber security policies for its high impact and medium impact BCS as required by Requirement R1 by the CIP	The Responsible Entity did not complete its review of the one or more documented cyber security policies as required by Requirement R1 within 18 calendar months of the previous review. (Requirement R1)
					OR

R#	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-003-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
		Requirement R1 by the CIP Senior Manager within 15 calendar months but did complete this approval in less than or equal to 17 calendar months of the previous approval. (R 1.1) OR The Responsible Entity documented one or more cyber security policies for its assets identified in CIP-002 containing low impact BCS, but did not address one of the seven topics required by Requirement R1. (R 1.2) OR The Responsible Entity did not complete its review of the one or more documented cyber security policies for its assets identified in CIP-002 containing low impact BCS as required by Requirement R1 within 15 calendar months but did complete this review in	Senior Manager within 17 calendar months but did complete this approval in less than or equal to 19 calendar months of the previous approval. (R 1.1) OR The Responsible Entity documented one or more cyber security policies for its assets identified in CIP-002 containing low impact BCS, but did not address two of the seven topics required by Requirement R1. (R 1.2) OR The Responsible Entity did not complete its review of the one or more documented cyber security policies for its assets identified in CIP-002 containing low impact BCS as required by Requirement R1 within 17 calendar months but did complete this review in less than or equal to 19 calendar	Senior Manager within 19 calendar months but did complete this approval in less than or equal to 21 calendar months of the previous approval. (Requirement R1) OR The Responsible Entity documented one or more cyber security policies for its assets identified in CIP-002 containing low impact BCS, but did not address four of the seven topics required by Requirement R1. (R 1.2) OR The Responsible Entity did not complete its review of the one or more documented cyber security policies for its assets identified in CIP-002 containing low impact BCS as required by Requirement R1 within 19 calendar months but did complete this review in less than or equal to 21	The Responsible Entity did not complete its approval of the one or more documented cyber security policies for its high impact and medium impact BCS as required by Requirement R1 by the CIP Senior Manager within 21 calendar months of the previous approval. (R 1.1) OR The Responsible Entity did not address six or more of the seven topics required by Requirement R1. (R 1.2) OR The Responsible Entity did not have any documented cyber security policies for its assets identified in CIP-002 containing low impact BCS as required by Requirement R1. (R1.2) OR

R#	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-003-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
		less than or equal to 17 calendar months of the previous review. (R 1.2) OR The Responsible Entity did not complete its approval of the one or more documented cyber security policies for its assets identified in CIP-002 containing low impact BCS as required by Requirement R1 by the CIP Senior Manager within 15 calendar months but did complete this approval in less than or equal to 17 calendar months of the previous approval. (R 1.2)	months of the previous review. (R 1.2) OR The Responsible Entity did not complete its approval of the one or more documented cyber security policies for its assets identified in CIP-002 containing low impact BCS as required by Requirement R1 by the CIP Senior Manager within 17 calendar months but did complete this approval in less than or equal to 19 calendar months of the previous approval. (R 1.2)	calendar months of the previous review. (R 1.2) OR The Responsible Entity did not complete its approval of the one or more documented cyber security policies for its assets identified in CIP-002 containing low impact BCS as required by Requirement R1 by the CIP Senior Manager within 19 calendar months but did complete this approval in less than or equal to 21 calendar months of the previous approval. (R 1.2)	The Responsible Entity did not complete its approval of the one or more documented cyber security policies for its assets identified in CIP-002 containing low impact BCS as required by Requirement R1 by the CIP Senior Manager within 21 calendar months of the previous approval. (R1.2)

R#	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-003-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
R2	Lower	The Responsible Entity failed to document cyber security awareness according to Requirement R2, Attachment 1, Section 1. (Requirement R2)	The Responsible Entity failed to reinforce cyber security practices at least once every 15 calendar months according to Requirement R2, Attachment 1, Section 1. (Requirement R2)	The Responsible Entity failed to implement the physical security controls according to Requirement R2, Attachment 1, Section 2. (Requirement R2)	The Responsible Entity failed to document and implement one or more cyber security plan(s) according to Requirement R2, Attachment 1. (Requirement R2)
		OR	OR	OR	
		The Responsible Entity failed to document its cyber security plan(s) for electronic access controls according to Requirement R2, Attachment 1, Section 3. (Requirement R2)	The Responsible Entity failed to document physical security controls according to Requirement R2, Attachment 1, Section 2. (Requirement R2)	The Responsible Entity failed to permit only necessary inbound and outbound electronic access controls according to Requirement R2, Attachment 1, Section 3.1. (Requirement R2)	
		OR	OR	OR	
		The Responsible Entity failed to document one or more Cyber Security Incident response plan(s) according to Requirement R2, Attachment 1, Section 4. (Requirement R2)	The Responsible Entity failed to document electronic access controls according to Requirement R2, Attachment 1, Section 3. (Requirement R2)	The Responsible Entity documented failed to test each Cyber Security Incident response plan(s) at least once every 36 calendar months according to Requirement R2, Attachment 1, Section 4. (Requirement R2)	
		OR	OR	OR	
		The Responsible Entity failed to update each Cyber Security Incident response plan(s) within 180 days according to	The Responsible Entity failed to implement authentication for all Dial-up Connectivity according to Requirement R2, Attachment 1, Section 3.2 (Requirement R2)	The Responsible Entity failed to notify the Electricity	

R#	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-003-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
		Requirement R2, Attachment 1, Section 4. (Requirement R2) OR The Responsible Entity failed to manage its Transient Cyber Asset(s) according to Requirement R2, Attachment 1, Section 5.1. (Requirement R2) OR The Responsible Entity failed to document the Removable Media section(s) according to Requirement R2, Attachment 1, Section 5.3. (Requirement R2) OR The Responsible Entity implemented vendor electronic remote access security controls but failed to document its cyber security process for vendor electronic remote access security controls according to	OR The Responsible Entity failed to include the process for identification, classification, and response to Cyber Security Incidents according to Requirement R2, Attachment 1, Section 4. (Requirement R2) OR The Responsible Entity failed to document the determination of whether an identified Cyber Security Incident is a Reportable Cyber Security Incident and subsequent notification to the Electricity Information Sharing and Analysis Center (E-ISAC) according to Requirement R2, Attachment 1, Section 4. (Requirement R2) OR The Responsible Entity failed to document mitigation for the introduction of malicious code	Information Sharing and Analysis Center (E-ISAC) according to Requirement R2, Attachment 1, Section 4. (Requirement R2) OR The Responsible Entity failed to implement mitigation for the introduction of malicious code for Transient Cyber Assets managed by the Responsible Entity according to Requirement R2, Attachment 1, Section 5.1. (Requirement R2) OR The Responsible Entity failed to implement mitigation for the introduction of malicious code for Transient Cyber Assets managed by a party other than the Responsible Entity according to Requirement R2, Attachment 1, Section 5.2. (Requirement R2)	

R#	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-003-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
		Requirement R2, Attachment 1, Section 6 (Requirement R2)	for Transient Cyber Assets managed by the Responsible Entity according to Requirement R2, Attachment 1, Sections 5.1 and 5.3. (Requirement R2) OR The Responsible Entity failed to document mitigation for the introduction of malicious code for Transient Cyber Assets managed by a party other than the Responsible Entity according to Requirement R2, Attachment 1, Section 5.2. (Requirement R2) OR The Responsible Entity failed to implement the Removable Media section(s) according to Requirement R2, Attachment 1, Section 5.3. (Requirement R2) OR	OR The Responsible Entity failed to implement mitigation for the threat of detected malicious code on the Removable Media prior to connecting Removable Media according to Requirement R2, Attachment 1, Section 5.3. (Requirement R2) OR The Responsible Entity failed to document and implement its cyber security process for vendor electronic remote access security controls according to Requirement R2, Attachment 1, Section 6. (Requirement R2)	

R#	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-003-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
			The Responsible Entity documented its cyber security process for vendor electronic remote access security controls but failed to implement vendor electronic remote access security controls according to Requirement R2. Attachment 1, Section 6. (Requirement R2)		
R3	Medium	The Responsible Entity did not document changes to the CIP Senior Manager within 30 calendar days but did document this change in less than 40 calendar days of the change. (Requirement R3)	The Responsible Entity did not document changes to the CIP Senior Manager within 40 calendar days but did document this change in less than 50 calendar days of the change. (Requirement R3)	The Responsible Entity did not document changes to the CIP Senior Manager within 50 calendar days but did document this change in less than 60 calendar days of the change. (Requirement R3)	The Responsible Entity did not identify, by name, a CIP Senior Manager. OR The Responsible Entity did not document changes to the CIP Senior Manager within 60 calendar days of the change. (Requirement R3)

R#	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-003-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
R4	Lower	The Responsible Entity did not document changes to the delegate within 30 calendar days but did document this change in less than 45 calendar days of the change. (Requirement R4)	The Responsible Entity did not document changes to the delegate within 45 calendar days but did document this change in less than 60 calendar days of the change. (Requirement R4)	The Responsible Entity did not document changes to the delegate within 60 calendar days but did document this change in less than 75 calendar days of the change. (Requirement R4)	The Responsible Entity does not have a process to delegate actions from the CIP Senior Manager. (Requirement R4) OR The Responsible Entity did not document changes to the delegate within 75 calendar days of the change. (Requirement R4)

D. Regional Variances

None.

E. Interpretations

None.

F. Associated Documents

None.

Version History

Version	Date	Action	Change Tracking

Balancing Authority	The responsible entity that integrates resource plans ahead of time, maintains Demand and resource balance within a Balancing Authority Area, and supports Interconnection frequency in real time.
BES Cyber Asset (BCA)	A Cyber Asset that if rendered unavailable, degraded, or misused would, within 15 minutes of its required operation, misoperation, or non operation, adversely impact one or more Facilities, systems, or equipment, which, if destroyed, degraded, or otherwise rendered unavailable when needed, would affect the reliable operation of the Bulk Electric System. Redundancy of affected Facilities, systems, and equipment shall not be considered when determining adverse impact. Each BES Cyber Asset is included in one or more BES Cyber Systems.
BES Cyber System (BCS)	One or more BES Cyber Assets logically grouped by a responsible entity to perform one or more reliability tasks for a functional entity.
BES Cyber System Information (BCSI)	Information about the BES Cyber System that could be used to gain unauthorized access or pose a security threat to the BES Cyber System. BES Cyber System Information does not include individual pieces of information that by themselves do not pose a threat or could not be used to allow unauthorized access to BES Cyber Systems, such as, but not limited to, device names, individual IP addresses without context, ESP names, or policy statements. Examples of BES Cyber System Information may include, but are not limited to, security procedures or security information about BES Cyber Systems, Physical Access Control Systems, and Electronic Access Control or Monitoring Systems that is not publicly available and could be used to allow unauthorized access or unauthorized distribution; collections of network addresses; and network topology of the BES Cyber System.
Blackstart Resource	A generating unit(s) and its associated set of equipment which has the ability to be started without support from the System or is designed to remain energized without connection to the remainder of the System, with the ability to energize a bus, meeting the Transmission Operator's restoration plan needs for Real and Reactive Power capability, frequency and voltage control, and that has been included in the Transmission Operator's restoration plan.
Bulk Electric System (BES)	Unless modified by the lists shown below, all Transmission Elements operated at 100 kV or higher and Real Power and Reactive Power resources connected at 100 kV or higher. This does not include facilities used in the local distribution of electric energy. Inclusions: • I1 - Transformers with the primary terminal and at least one secondary terminal operated at 100 kV or higher unless excluded by application of Exclusion E1 or E3. • I2 – Generating resource(s) including the generator terminals through the high-side of the step-up transformer(s) connected at a voltage of 100 kV or above with:

	a) Gross individual nameplate rating greater than 20 MVA. Or, b) Gross plant/facility aggregate nameplate rating greater than 75 MVA. • I3 - Blackstart Resources identified in the Transmission Operator's restoration plan. • I4 - Dispersed power producing resources that aggregate to a total capacity greater than 75 MVA (gross nameplate rating), and that are connected through a system designed primarily for delivering such capacity to a common point of connection at a voltage of 100 kV or above. Thus, the facilities designated as BES are: a) The individual resources, and The system designed primarily for delivering capacity from the point where those resources aggregate to greater than 75 MVA to a common point of connection at a voltage of 100 kV or above. • I5 –Static or dynamic devices (excluding generators) dedicated to supplying or absorbing Reactive Power that are connected at 100 kV or higher, or through a dedicated transformer with a high-side voltage of 100 kV or higher, or through a transformer that is designated in Inclusion I1 unless excluded by application of Exclusion E4 Exclusions: • E1 - Radial systems: A group of contiguous transmission Elements that emanates from a single point of connection of 100 kV or higher and: a) Only serves Load. Or, b) Only includes generation resources, not identified in Inclusions I2, I3, or I4, with an aggregate capacity less than or equal to 75 MVA (gross nameplate rating). Or, c) Where the radial system serves Load and includes generation resources, not identified in Inclusions I2, I3 or I4, with an aggregate capacity of non- retail generation less than or equal to 75 MVA (gross nameplate rating). Note 1 – A normally open switching device between radial systems, as depicted on prints or one-line diagrams for example, does not affect this exclusion. Note 2 – The presence of a contiguous loop, operated at a voltage level of 50 kV or less, between configurations being considered as radial systems, does not affect this exclusion. • E2 - A generating unit or multiple generating units on the customer's side of the retail meter that serve all or part of the retail Load with electric energy if: (i) the net capacity provided to the BES does not exceed 75 MVA, and (ii) standby, back-up, and maintenance power services are provided to the generating unit or multiple generating units or to the retail Load by a Balancing Authority, or provided pursuant to a binding obligation with a Generator Owner or Generator Operator, or under terms approved by the applicable regulatory authority. • E3 - Local networks (LN): A group of contiguous transmission Elements operated at less than 300 kV that distribute power to Load rather than transfer bulk power across the interconnected system. LN's emanate from multiple points of connection at 100 kV or higher to improve the level of service to retail customers and not to accommodate bulk power transfer across the interconnected system. The LN is characterized by all of the
--	--

	following: a) Limits on connected generation: The LN and its underlying Elements do not include generation resources identified in Inclusions I2, I3, or I4 and do not have an aggregate capacity of non-retail generation greater than 75 MVA (gross nameplate rating); b) Real Power flows only into the LN and the LN does not transfer energy originating outside the LN for delivery through the LN; and c) Not part of a Flowgate or transfer path: The LN does not contain any part of a permanent Flowgate in the Eastern Interconnection, a major transfer path within the Western Interconnection, or a comparable monitored Facility in the ERCOT or Quebec Interconnections, and is not a monitored Facility included in an Interconnection Reliability Operating Limit (IROL). • E4 – Reactive Power devices installed for the sole benefit of a retail customer(s). Note - Elements may be included or excluded on a case-by-case basis through b) the Rules of Procedure exception process.
CIP Exceptional Circumstance	A situation that involves or threatens to involve one or more of the following, or similar, conditions that impact safety or BES reliability: a risk of injury or death; a natural disaster; civil unrest; an imminent or existing hardware, software, or equipment failure; a Cyber Security Incident requiring emergency assistance; a response by emergency services; the enactment of a mutual assistance agreement; or an impediment of large scale workforce availability.
CIP Senior Manager	A single official with the authority to bind the registered entity to adhere to the requirements within the CIP Standards, CIP-002 through CIP-015.
Control Center	One or more facilities hosting operating personnel that monitor and control the Bulk Electric System (BES) in real-time to perform the reliability tasks, including their associated data centers, of: 1) a Reliability Coordinator, 2) a Balancing Authority, 3) a Transmission Operator for transmission Facilities at two or more locations, or 4) a Generator Operator for generation Facilities at two or more locations.
Cranking Path	A portion of the electric system that can be isolated and then energized to deliver electric power from a generation source to enable the startup of one or more other generating units.
Cyber Assets (CA)	Programmable electronic devices, including the hardware, software, and data in those devices.
Cyber Security Incident (CSI)	A malicious act or suspicious event that: • For a high or medium impact BES Cyber System, compromises or attempts to compromise (1) an Electronic Security Perimeter, (2) a Physical Security Perimeter, or (3) an Electronic Access Control or Monitoring System; or Disrupts or attempts to disrupt the operation of a BES Cyber System
Distribution Provider	Provides and operates the “wires” between the transmission system and the end-use customer. For those end-use customers who are served at transmission voltages, the Transmission Owner also serves as the Distribution

	Provider. Thus, the Distribution Provider is not defined by a specific voltage, but rather as performing the distribution function at any voltage
Electronic Access Control or Monitoring Systems (EACMS)	Cyber Assets that perform electronic access control or electronic access monitoring of the Electronic Security Perimeter(s) or BES Cyber Systems. This includes Intermediate Systems.
Electronic Access Point (EAP)	A Cyber Asset interface on an Electronic Security Perimeter that allows routable communication between Cyber Assets outside an Electronic Security Perimeter and Cyber Assets inside an Electronic Security Perimeter.
Electronic Security Perimeter (ESP)	The logical border surrounding a network to which BES Cyber Systems are connected using a routable protocol.
Element	Any electrical device with terminals that may be connected to other electrical devices such as a generator, transformer, circuit breaker, bus section, or transmission line. An Element may be comprised of one or more components.
External Routable Connectivity (ERC)	Programmable electronic devices, excluding Shared Cyber Infrastructure, including the hardware, software, and data in those devices. Application containers are considered software of Virtual Cyber Assets (VCAs) or Cyber Assets. VCAs are not considered software or data of Cyber Assets.
Facility	A set of electrical equipment that operates as a single Bulk Electric System Element (e.g., a line, a generator, a shunt compensator, transformer, etc.)
Inoperable or Damaged	The loss of transmission elements preventing the facility from performing its intended function or physical destruction that prevents the facility from being restored to service through normal operating procedures
Interactive Remote Access (IRA)	User-initiated access by a person employing a remote access client or other remote access technology using a routable protocol. Remote access originates from a Cyber Asset that is not an Intermediate System and not located within any of the Responsible Entity's Electronic Security Perimeter(s) or at a defined Electronic Access Point (EAP). Remote access may be initiated from: 1) Cyber Assets used or owned by the Responsible Entity, 2) Cyber Assets used or owned by employees, and 3) Cyber Assets
Physical Access Control Systems (PACS)	Cyber Assets that control, alert, or log access to the Physical Security Perimeter(s), exclusive of locally mounted hardware or devices at the Physical Security Perimeter such as motion sensors, electronic lock control mechanisms, and badge readers.
Physical Security Perimeter (PSP)	The physical border surrounding locations in which BES Cyber Assets, BES Cyber Systems, or Electronic Access Control or Monitoring Systems reside, and for which access is controlled.

Protected Cyber Assets (PCA)	One or more Cyber Assets connected using a routable protocol within or on an Electronic Security Perimeter that is not part of the highest impact BES Cyber System within the same Electronic Security Perimeter. The impact rating of Protected Cyber Assets is equal to the highest rated BES Cyber System in the same ESP.
Real-time Assessment	An evaluation of system conditions using Real time data to assess existing (pre-Contingency) and potential (post Contingency) operating conditions. The assessment shall reflect applicable inputs including, but not limited to: load; generation output levels; known Protection System and Remedial Action Scheme status or degradation, functions, and limitations; Transmission outages; generator outages; Interchange; Facility Ratings; and identified phase angle and equipment limitations. (Realtime Assessment may be provided through internal systems or through third party services.)
Remedial Action Scheme (RAS)	The following do not individually constitute a RAS: a) Protection Systems installed for the purpose of detecting Faults on BES Elements and isolating the faulted Elements b) Schemes for automatic underfrequency load shedding (UFLS) and automatic undervoltage load shedding (UVLS) comprised of only distributed relays c) Out-of-step tripping and power swing blocking d) Automatic reclosing schemes e) Schemes applied on an Element for non-Fault conditions, such as, but not limited to, generator loss-of- field, transformer top-oil temperature, overvoltage, or overload to protect the Element against damage by removing it from service f) Controllers that switch or regulate one or more of the following: series or shunt reactive devices, flexible alternating current transmission system (FACTS) devices, phase-shifting transformers, variable-frequency transformers, or tap-changing transformers; and, that are located at and monitor quantities solely at the same station as the Element being switched or regulated g) FACTS controllers that remotely switch static shunt reactive devices located at other stations to regulate the output of a single FACTS device h) Schemes or controllers that remotely switch shunt reactors and shunt capacitors for voltage regulation that would otherwise be manually switched i) Schemes that automatically de-energize a line for a non-Fault operation when one end of the line is open j) Schemes that provide anti-islanding protection (e.g., protect load from effects of being isolated with generation that may not be capable of maintaining acceptable frequency and voltage) k) Automatic sequences that proceed when manually initiated solely by a System Operator l) Modulation of HVdc or FACTS via supplementary controls, such as angle damping or frequency damping applied to damp local or inter-area oscillations m) Sub-synchronous resonance (SSR) protection schemes that directly detect sub-synchronous quantities (e.g., currents or torsional oscillations) n) Generator controls such as, but not limited to, automatic generation

	control (AGC), generation excitation [e.g. automatic voltage regulation (AVR) and power system stabilizers(PSS)], fast valving, and speed governing
Reportable Cyber Security Incident	A Cyber Security Incident that compromised or disrupted: • A BES Cyber System that performs one or more reliability tasks of a functional entity; • An Electronic Security Perimeter of a high or medium impact BES CyberSystem; or • An Electronic Access Control or Monitoring System of a high or medium impact BES Cyber System
Shared Cyber Infrastructure (SCI)	One or more programmable electronic devices, including the software that shares the devices' resources, that: • Hosts one or more Virtual Cyber Assets (VCA) included in a BES Cyber Systems (BCS) or their associated Electronic Access Control or Monitoring Systems (EACMS) or Physical Access Control Systems (PACS); and hosts one or more VCAs that are not included in, or associated with, BCS of the same impact categorization; or • Provides storage resources required for system functionality of one or more Cyber Assets or VCAs included in a BCS or their associated EACMS or PACS; and also for one or more Cyber Assets or VCAs that are not included in, or associated with, BCS of the same impact categorization. SCI does not include the supported VCAs or Cyber Assets with which it shares its resources.
Transient Cyber Asset	A Cyber Asset that is: 1. capable of transmitting or transferring executable code, 2. not included in a BES Cyber System, 3. not a Protected Cyber Asset (PCA) associated with high or medium impact BES Cyber Systems, and 4. directly connected (e.g., using Ethernet, serial, Universal Serial Bus, or wireless including near field or Bluetooth communication) for 30 consecutive calendar days or less to a: • BES Cyber Asset, • network within an Electronic Security Perimeter (ESP) containing high or medium impact BES Cyber Systems, or • PCA associated with high or medium impact BES Cyber Systems. Examples of Transient Cyber Assets include, but are not limited to, Cyber Assets used for data transfer, vulnerability assessment, maintenance, or troubleshooting purposes.
Transmission	An interconnected group of lines and associated equipment for the movement or transfer of electric energy between points of supply and points at which it is transformed for delivery to customers or is delivered to other electric systems.
Transmission Line	A system of structures, wires, insulators and associated hardware that carry electric energy from one point to another in an electric power system. Lines are operated at relatively high voltages varying from 69 kV up to 765 kV, and are capable of transmitting large quantities of electricity over long distances.

Transmission Planner	The entity that develops a long-term (generally one year and beyond) plan for the reliability (adequacy) of the interconnected bulk electric transmission systems within its portion of the Planning Authority area.
Transmission Operator	The entity responsible for the reliability of its “local” transmission system, and that operates or directs the operations of the transmission Facilities.
Transmission Owner	The entity that owns and maintains transmission Facilities.
Undervoltage Load Shedding Program	An automatic load shedding program, consisting of distributed relays and controls, used to mitigate undervoltage conditions impacting the Bulk Electric System (BES), leading to voltage instability, voltage collapse, or Cascading. Centrally controlled undervoltage-based load shedding is not included.
Virtual Cyber Asset	A logical instance of an operating system or firmware, currently executing on a virtual machine hosted on a BES Cyber Asset; Electronic Access Control or Monitoring System; Physical Access Control System; Protected Cyber Asset; or Shared Cyber Infrastructure (SCI). Virtual Cyber Assets (VCAs) do not include: • Logical instances that are being actively remediated in an environment that isolates routable connectivity from BES Cyber Systems; • Dormant file-based images that contain operating systems or firmware; or • SCI or Cyber Assets that host VCAs. • Application containers are considered software of VCAs or Cyber Assets